Iris Recognition-Based Authentication System Using Daugman's Algorithm

Hari Sankar A
School of Computing
Amrita Vishwa Vidyapeetham
Amritapuri, India
am.sc.u4cse23221@am.students.amrita.edu

Abhinav Dileep
School of Computing
Amrita Vishwa Vidyapeetham
Amritapuri, India
am.sc.u4cse23202@am.students.amrita.edu

Ayyappadas M T
School of Computing
Amrita Vishwa Vidyapeetham
Amritapuri, India
am.sc.u4cse23209@am.students.amrita.edu

Ajith Ashok
School of Computing
Amrita Vishwa Vidyapeetham
Amritapuri, India
am.sc.u4cse23204@am.students.amrita.edu

Pranav Pradeep
School of Computing
Amrita Vishwa Vidyapeetham
Amritapuri, India
am.sc.u4cse23243@am.students.amrita.edu

***Abstract*—Passwords and tokens can be shared, stolen or guessed, whereas the human iris is a stable and highly distinctive biometric trait. This paper presents a complete iris-recognition-based authentication system built on Daugman's algorithm. The system localizes the pupil and iris with a circular integro-differential operator, unwraps the iris with the rubber-sheet model, encodes it into a 16,384-bit iris code using two-scale one-dimensional Log-Gabor filters, and verifies a claimed identity with a rotation-tolerant, noise-masked Hamming distance. Because a leaked biometric template cannot be revoked like a password, the system also stores templates only as authenticated ciphertext, binds each template to its account, refuses duplicate enrollments and replayed captures, rate-limits failed verifications without revealing which accounts exist, and records every event in a tamper-evident audit log; a threat model and privacy analysis state which attacks and privacy properties are not covered. Evaluation on CASIA-Iris-Interval uses a subject-disjoint protocol: parameters and thresholds were tuned on subjects 001–060 and results are reported on the remaining subjects (314 eyes). On 6,632 genuine and 2,126,513 impostor comparisons the system reaches an equal error rate of 1.94%, a decidability index of 4.24 and 96.5% rank-1 identification accuracy, and a verification takes about 15.5 ms on a standard CPU. Ablation and degradation experiments show which design choices matter, and the limitations of a single-dataset, classical-segmentation study are discussed.**

***Index Terms*—Iris Recognition, Biometric Authentication, Daugman Algorithm, Iris Code, Log-Gabor Filter, Hamming Distance, Template Protection.**

I. Introduction

Authentication based on what a user knows or holds is vulnerable to sharing, theft and guessing, which motivates biometric authentication based on who the user is. Among the physiological traits in use, the iris is attractive because its texture is formed early in life, is considered stable for most of adulthood, and is protected inside the eye. Together these properties give iris codes a very low probability of false matches between different eyes [1], [3]. Iris recognition is deployed at borders, in national identity programmes and in access control.

Building an iris-authentication system, however, involves more than the matching algorithm. The image must be segmented despite eyelids, eyelashes and reflections; the iris must be represented in a form that tolerates pupil dilation and head tilt; and, because an iris cannot be changed once compromised, the stored template must be protected at least as carefully as a password hash [10], [11].

This project therefore implements an end-to-end iris authentication system with two goals: (i) a faithful, reproducible implementation of Daugman's pipeline [2], evaluated with a rigorous subject-disjoint protocol, and (ii) a security layer around the biometric core consisting of encrypted template storage, duplicate-identity detection, lockout and audit logging. All results in this paper are produced by the accompanying code, and every figure and number is regenerated from the evaluation scripts.

The remainder of the paper is organized as follows. Section II reviews related work. Section III describes the proposed system and Section IV the methodology. Section V covers the implementation, Section VI presents results and discussion, Section VII summarizes the security features, Section VIII gives the threat model and privacy analysis, and Sections IX and X conclude and outline future work.

II. Literature Review

Daugman introduced the first operational iris-recognition algorithm, in which the iris is located by an integro-differential

operator, mapped to a dimensionless polar coordinate system, encoded by the phase of two-dimensional Gabor wavelets into a binary iris code, and compared by the fractional Hamming distance [1], [2]. Because different irises produce codes that behave like independent random bit strings, the distribution of impostor distances is narrow and centred near 0.5, which makes very low false-match rates attainable [3]. Wildes proposed an alternative based on a Hough-transform localization and Laplacian-of-Gaussian pyramid features with normalized correlation matching [4].

Open implementations made the approach reproducible. Masek's widely used implementation replaced the two-dimensional filters with one-dimensional Log-Gabor filters applied row-wise to the normalized image [5]; Log-Gabor filters, introduced by Field, have no DC response and a long high-frequency tail, which suits natural textures [6]. Bowyer et al. surveyed the field, covering segmentation, normalization, feature extraction and the dominant sources of error [7]. Large-scale public evaluations such as NIST IREX have since benchmarked commercial and academic algorithms on standard iris images [8], and the CASIA iris image databases [13] remain the most common research benchmark for classical methods. More recently, deep convolutional networks have been used to learn iris representations [9]; they require large labelled collections and are not examined here.

A second line of work concerns the security of biometric systems themselves. Unlike passwords, biometric traits cannot be revoked, so a compromised template is compromised for life. Ratha et al. analysed attack points in biometric authentication systems and proposed cancelable (revocable) templates [11]; Jain et al. discuss the same vulnerabilities from the standpoint of system design [10]. Presentation-attack detection is standardized in ISO/IEC 30107 [12]. Many academic prototypes concentrate on recognition accuracy and store templates in plain files, so we treat secure storage, duplicate-identity detection, rate limiting and auditing as first-class parts of the system and verify each with automated tests.

III. Proposed System

Fig. 1 shows the system. A near-infrared (NIR) eye image first passes through a common front end: segmentation, normalization and encoding produce an iris code and a validity mask. In enrollment, the new template is first compared with all enrolled templates; if it matches an existing user it is refused as a duplicate identity. Otherwise it is encrypted with an authenticated cipher and written to the database together with an audit entry.

In verification, the user claims an identity. The system first checks that the claimed account is not locked by repeated failures, then decrypts and authenticates the stored template (any modification of the ciphertext is detected), computes the masked, rotation-tolerant Hamming distance between the probe and stored codes, and grants access only if the distance is below the threshold of the selected security level. Each outcome—granted, rejected, locked or error—is written to the audit log. The eye image itself is never stored.

IV. Methodology

A. Image Acquisition and Dataset

Experiments use CASIA-Iris-Interval [13], which contains 2,639 NIR images of 395 eyes from 249 subjects, captured with a close-up iris camera with circular NIR illumination; each image is 320×280 pixels. The illuminators produce a ring of bright corneal reflections inside the pupil that must be handled during segmentation. File names carry no session label, so genuine pairs are taken as all pairs of different images of the same eye.

B. Iris Segmentation

The pupil is found first. A grayscale morphological opening with a 15×15 elliptical element removes the small bright corneal reflections. The opened image is thresholded at several levels between its 1st percentile and its median intensity; for each level, connected components are scored by circularity, fill ratio, proximity to the image centre, area and the number of corneal reflections they contain, and components that are too small, too elongated or at the image border are discarded. The best component gives an initial pupil circle.

Both boundaries are then refined with Daugman's integro-differential operator [2], which searches for the circle (r, x_0, y_0) maximizing the Gaussian-smoothed radial derivative of the mean intensity along the circle:

$$\max_{(r,x_0,y_0)} \left| G_\sigma(r) * \frac{\partial}{\partial r} \oint_{r,x_0,y_0} \frac{I(x,y)}{2\pi r}\, ds \right|. \tag{1}$$

The pupil boundary is refined over centre offsets of ± 5 px and radii between 0.7 and 1.25 times the initial radius, using the opened image so that reflections do not attract the circle. The outer iris boundary is searched over centre offsets of ± 6 px around the pupil centre and radii between $\max(1.6\, r_p,\ 85$ px$)$ and $\min(3.6\, r_p,\ 125$ px$)$. Only the left and right angular sectors (-35° to 35° and 145° to 215°) contribute to the integral because the upper and lower parts of the limbus are covered by eyelids and eyelashes. Because the camera operates at a fixed distance, the iris radius prior encodes a property of the acquisition setup rather than of individual images; its effect is quantified in Section VI-E. A segmentation is rejected, and the image counted as a failure to acquire, if the boundary gradient is weak, the pupil and iris centres are more than $0.2\, r_i$ apart, or r_p / r_i lies outside $[0.2, 0.7]$.

C. Normalization

The annulus between the pupil and iris boundaries is mapped onto a fixed 64×512 rectangle with Daugman's rubber-sheet model, which linearly interpolates between corresponding points on the two (not necessarily concentric) boundaries:

$$x(r,\theta) = (1-r)\, x_p(\theta) + r\, x_i(\theta), \tag{2}$$

and likewise for y, with $r \in [0,1]$. This removes the effect of pupil dilation and of the eye's position and size. A validity mask marks pixels that should not contribute: specular highlights, pixels much darker than the iris median (eyelashes

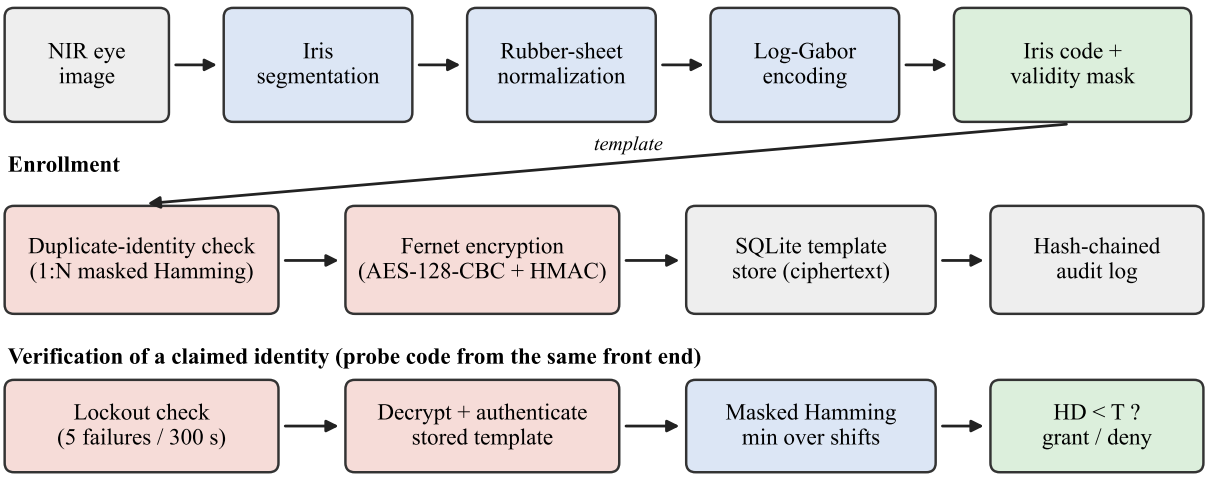


Fig. 1. System architecture. The front end (blue) is shared by enrollment and verification; red blocks are security controls.

and shadows), pixels much brighter than it (eyelid and sclera glare), samples outside the image, and the rows adjacent to the pupil boundary.

D. Feature Encoding

Each normalized row is filtered in the Fourier domain with a one-dimensional Log-Gabor filter

$$G(f) = \exp\left(-\frac{(\ln(f/f_0))^2}{2\,(\ln \sigma_f)^2}\right), \quad f > 0, \tag{3}$$

with $\sigma_f = 0.5$ and two centre wavelengths of 24 and 48 samples, giving a complex response z at every location. The response is averaged over groups of four radial rows and subsampled by two angularly, so the code has 16 rows and 256 columns. Phase is quantized to two bits per filter, $b = [\,\mathrm{Re}(z) > 0,\ \mathrm{Im}(z) > 0\,]$, yielding $16 \times 256 \times 4 =$16,384 bits. A bit is marked reliable only if all pixels contributing to it are valid; the outer four radial rows, which suffer most from occlusion, are always masked.

E. Matching

Two codes C_A, C_B with masks M_A, M_B are compared by the fractional Hamming distance over bits that are reliable in both, minimized over a set $\mathcal{S}$ of angular shifts that compensates for head tilt:

$$\mathrm{HD} = \min_{s \in \mathcal{S}} \frac{\|(C_A \oplus \mathrm{R}_s(C_B)) \cap M_A \cap \mathrm{R}_s(M_B)\|}{\|M_A \cap \mathrm{R}_s(M_B)\|}, \tag{4}$$

where R_s circularly shifts the code by s columns. We use $\mathcal{S} = \{-6, \ldots, 6\}$ ($\pm 8.4°$). If fewer than 15% of the bits are jointly reliable, the comparison is uninformative and the distance is set to the chance level 0.5. A claimed identity is accepted if $\mathrm{HD} < T$.

F. Secure Template Storage

Only the packed code and mask are stored, never the eye image. Each template is encrypted with Fernet, an authenticated-encryption scheme from the Python `cryptography` package that combines AES-128 in CBC mode with an HMAC-SHA256 tag [14], so tampering is detected before any data is parsed. The encrypted plaintext also contains the account name, so a valid ciphertext copied from one account to another is rejected when it is decrypted. The key is kept outside the data directory with owner-only permissions; it can instead be derived from a passphrase with scrypt or supplied through the environment, and it can be rotated, which re-encrypts every template. Usernames are validated against a strict pattern and lower-cased so that case variants cannot create look-alike accounts, and all database access uses parameterized queries. Enrollment is atomic. A quality gate refuses images with too few usable bits, and the new template is compared with every enrolled template using a fixed policy threshold, so one iris cannot hold two accounts; the refusal does not name the other account, although the operator can see it in the log. Accounts are never created with elevated privileges, and deleted templates are overwritten in the database file (SQLite secure delete).

G. Verification Hardening

Verification performs the same work and returns the same kind of result whether or not the claimed account exists, so it cannot be used to enumerate usernames. Failed attempts are limited per account (5 in 300 seconds) and per client (20 in 300 seconds, which stops one client from spraying many usernames); a lock is recorded once per window so that an attacker cannot flood the log. Exact replays are rejected: a probe whose code is identical to the enrolled capture or to a previously accepted capture is refused. Two different genuine

captures of the same eye were never closer than 0.052 in our data (8,819 genuine pairs), whereas a replayed file gives a distance of 0, and the rejection threshold is 0.03. This stops reuse of a stolen image file but not a fresh presentation attack. The decision threshold is server-side policy and cannot be chosen by the person being verified.

H. Tamper-Evident Audit Logging

Every enrollment, verification and integrity event is appended to an audit table with timestamp, client, username, outcome and distance. Each row carries an HMAC-SHA256 over its contents and the previous row's hash, and a keyed head value records the latest row, so editing, deleting, reordering or truncating entries is detected when the chain is verified; the application shows the result in the audit view. The chain key is stored encrypted under the master key. Rolling the whole database back to an older consistent snapshot is not detected.

I. Application Hardening

The demonstration server listens on the loopback interface only, limits uploads to 5 MB, and rejects from the file header alone any image that is not JPEG, PNG or BMP or that exceeds one megapixel, so decompression bombs are never decoded; uploads are never written to disk. Pillow, which Streamlit installs, has known vulnerabilities with no fixed release for our Python version, so it is not used to parse untrusted files. An optional administrator password restricts enrollment, the audit log and the security level, stops the Verify page from listing accounts, and is compared in constant time behind a global throttle. Match scores are hidden unless the operator enables them for a presentation, because a visible score lets an attacker adjust an image step by step towards a match; the lockout limits such attempts. Error messages are fixed strings and framework tracebacks are disabled. Dependency versions are pinned and were audited with pip-audit.

V. Implementation

The system is implemented in Python using OpenCV [15] for image processing, NumPy and SciPy for numerical work, and the `cryptography` package for encryption; the template store uses SQLite. Each pipeline stage is a separate module with a fixed interface (segmentation, normalization, encoding, matching, pipeline), so stages can be developed and tested independently. A Streamlit application provides enrollment, verification, a pipeline-stage view that renders the boundaries, the normalized strip and the iris code, and an audit-log view, with three selectable security levels. For evaluation, all pairwise distances are computed as matrix products of ± 1 code matrices rather than by looping, and a test verifies that this vectorized routine agrees with the reference matcher on every sample pair. The repository contains 79 automated tests (22 for the biometric pipeline, 35 for the secure store, 14 for input validation and 8 for the web application).

Fig. 2 shows the stages for one test image.

TABLE I
System Parameters Used in the Experiments

Parameter	Value
Input image	320×280 NIR, 8-bit
Normalized strip	64×512 (radial × angular)
Iris radius prior	85–125 px
Log-Gabor wavelengths	24 and 48 samples
Log-Gabor bandwidth (σ_f)	0.5
Iris code size	16×256×4 = 16,384 bits
Radial rows used	1–12 of 16 (inner 75%)
Rotation shifts	± 6 columns ($\pm 8.4^\circ$)
Minimum joint valid bits	15% of code
Decision threshold (balanced)	0.44 (HD)
Server default threshold	0.423 (high security)
Failed-verification lockout	5 per user within 300 s
Template encryption	Fernet (AES-128-CBC, HMAC-SHA256)

TABLE II
Dataset and Subject-Disjoint Evaluation Protocol

Set	Subjects	Eyes	Images
Development (tuning)	001-060	81	553
Test (reported)	061-249	314	2,066
Not acquired (FTA)	–	–	20
Total	249	395	2,639

VI. Results and Discussion

A. Experimental Setup

Table I lists the parameters of the final system and Table II the evaluation protocol. To avoid optimistic estimates, the data are split by subject: all numeric parameters (segmentation search ranges, filter wavelengths, radial band) and the decision thresholds were selected by their equal error rate on subjects 001–060 (81 eyes, 553 images), and the remaining 314 eyes (2,066 images) were used only to report final results. One caveat applies: during development, segmentation failure cases were inspected visually on images drawn from the whole dataset, including test subjects, and the iris-radius range was set after looking at radius statistics over all images, so the test set is not strictly blind (Section VI-I). A genuine comparison is any pair of different images of the same eye; an impostor comparison is any pair of images from different eyes (left and right eyes of one person are treated as different eyes). Errors are reported with the standard metrics: False Accept Rate (FAR), False Reject Rate (FRR), Equal Error Rate (EER), the decidability index $d' = |\mu_g - \mu_i| / \sqrt{(\sigma_g^2 + \sigma_i^2)/2}$, ROC-AUC, and rank-1 identification accuracy.

B. Segmentation

2,619 of 2,639 images (20 failures, 0.76%) passed segmentation and the plausibility checks; the rest are counted as failures to acquire (FTA) and are not silently removed from the totals. The dataset has no ground-truth boundaries, so we do not report a pixel-level segmentation accuracy; instead segmentation quality is assessed visually (Fig. 3) and through its effect on recognition. The hardest cases, defined as the

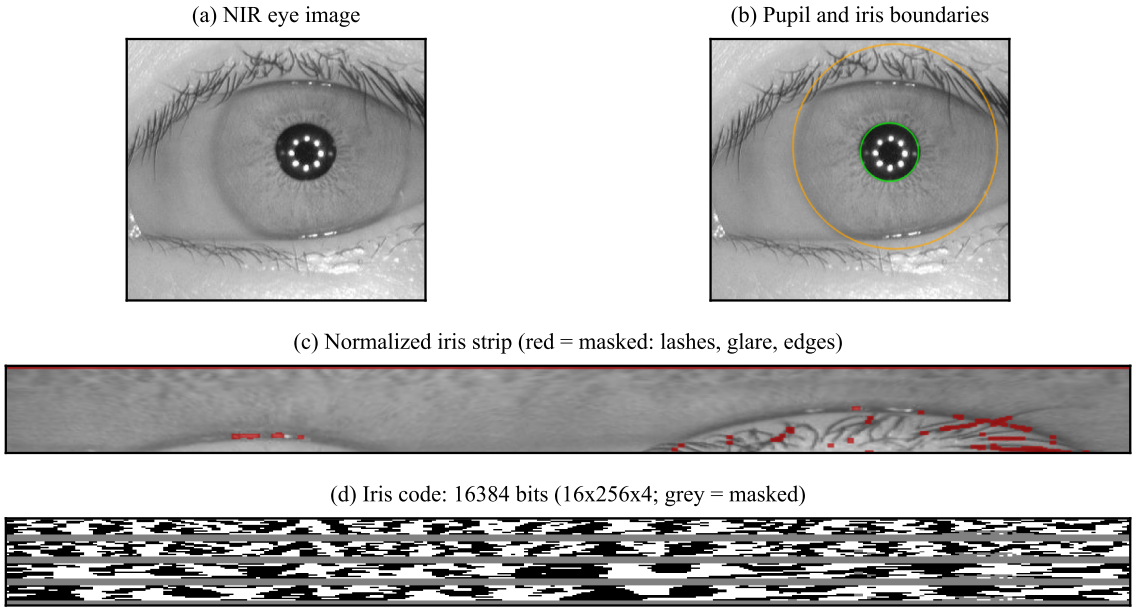


Fig. 2. Pipeline stages for one test image: (a) NIR eye image, (b) detected pupil (green) and iris (orange) boundaries, (c) normalized iris strip with masked pixels in red, (d) the resulting iris code.

images with the largest median distance to other images of the same eye, show that the dominant failure mode is a pupil circle distorted by eyelashes or an eyelid shadow that merges with the pupil.

C. Verification Performance

Table III reports verification performance. On the test subjects, genuine comparisons have a mean Hamming distance of 0.255 (standard deviation 0.073) and impostor comparisons 0.476 (0.015), which is close to the 0.5 expected for statistically independent codes. The two distributions are well separated (Fig. 4); d' is 4.24 and the ROC-AUC 0.9939. The EER is 1.94% on the test set against 1.51% on the development set. The difference is small, suggesting that tuning on the development subjects did not substantially overfit, though the test set is, as expected, slightly harder. In identification mode, using the first image of each of the 314 test eyes as the gallery and all 1,752 remaining images as probes, the nearest gallery code belongs to the correct eye 96.5% of the time.

The ROC and DET curves in Fig. 5 show that the genuine-accept rate falls only gradually as FAR is pushed down. The reason is visible in Table III: even at FAR $= 0.01\%$ the FRR is 3.88%. Judging from the hardest-case images in Fig. 3, this floor is most likely caused by a small fraction of genuine pairs in which at least one image is poorly segmented, rather than by the encoding itself; improving pupil localization on occluded eyes is therefore the most promising route to better accuracy.

D. Choice of Operating Point

A single threshold cannot suit every application. Table IV gives three security levels exposed in the demonstration application. Their thresholds were chosen on the development set (the EER point, and the points where the development FAR is 0.1% and 0.01%), and the error rates in the table were then measured on the independent test set. The measured FAR agrees closely with the development target at each level (0.13% against a 0.1% target at the high-security level, and 0.011% against a 0.01% target at the maximum-security level), showing that the thresholds transfer to unseen subjects. Moving from the balanced to the maximum-security level lowers the FAR by about two orders of magnitude at the cost of 3.81% FRR; for an access-control system where a false accept is much more costly than a retry, the higher levels are preferable. The rounded balanced threshold of 0.44, used in the robustness experiments, has FAR 1.26% and FRR 2.07% (Fig. 6); the application's default is the high-security level.

TABLE III
VERIFICATION PERFORMANCE (GENUINE/IMPOSTOR HAMMING DISTANCES)

Metric	Dev	Test
Genuine comparisons	2,187	6,632
Impostor comparisons	150,441	2,126,513
Mean genuine HD	0.239	0.255
Mean impostor HD	0.477	0.476
Decidability d'	4.73	4.24
ROC-AUC	0.9933	0.9939
EER	1.51%	1.94%
FRR at FAR = 1%	1.51%	2.13%
FRR at FAR = 0.1%	1.87%	3.00%
FRR at FAR = 0.01%	2.61%	3.88%
Rank-1 identification	–	96.5%

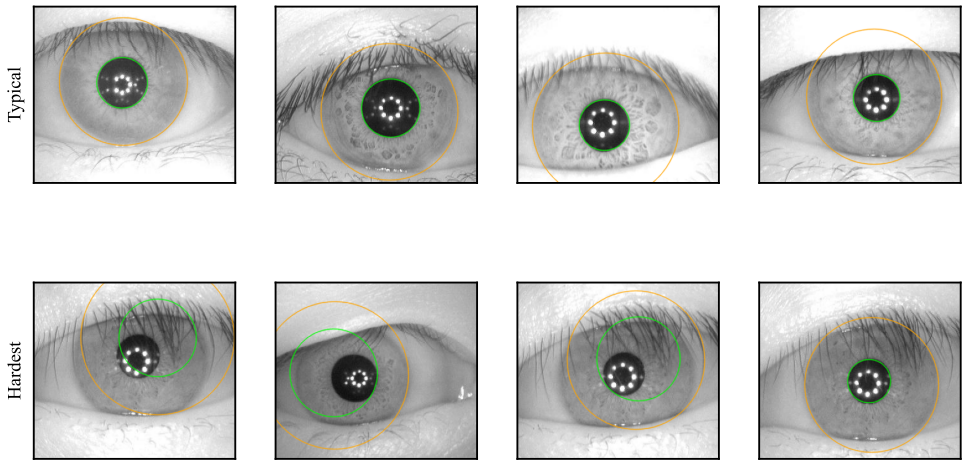


Fig. 3. Segmentation examples from the test subjects. Top: randomly chosen images. Bottom: the four images with the poorest genuine scores, where lashes or eyelids distort the pupil or iris circle.

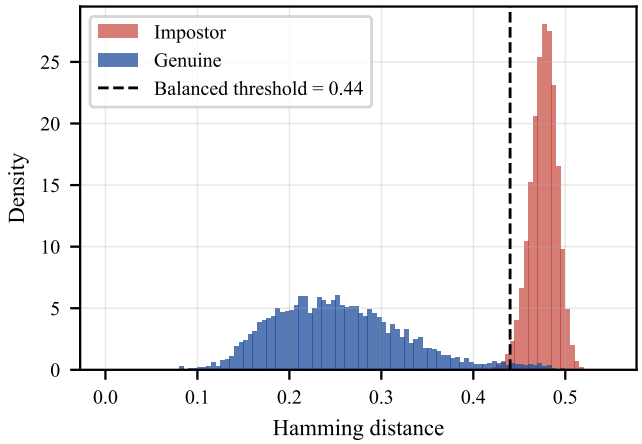


Fig. 4. Genuine and impostor Hamming-distance distributions on the test set and the balanced decision threshold.

TABLE IV
SECURITY LEVELS: THRESHOLDS CHOSEN ON THE DEVELOPMENT SET, ERROR RATES MEASURED ON THE TEST SET

Level	Threshold	FAR	FRR
Balanced	0.442	1.728%	1.96%
High security	0.423	0.126%	2.91%
Maximum security	0.406	0.011%	3.81%

E. Ablation Study

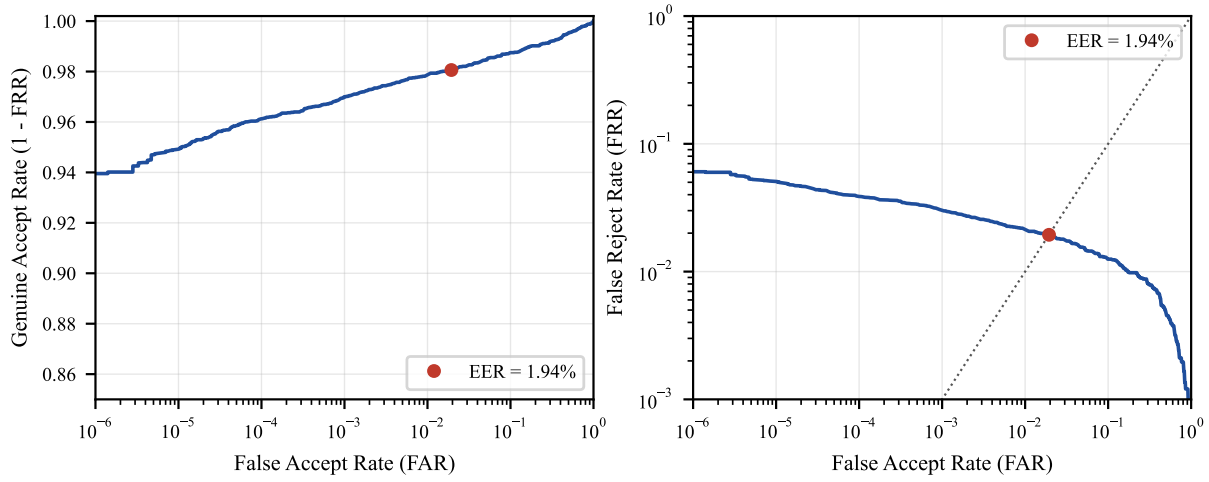
Table V removes one design element at a time and re-evaluates on the test set. Rotation compensation matters most: restricting the comparison to zero shift raises the EER from 1.94% to 7.85% (4.0 times higher), because even small head tilts misalign the codes. The iris-radius prior in the segmentation also helps (EER 2.56% without it): without a prior, the outer-boundary search is occasionally attracted to the collarette or to eyelid edges. Using all radial rows instead of the inner 75% raises the EER to 2.21%, consistent with the outer iris being more occluded. Excluding the noise mask has a smaller effect (2.12%); in our implementation pixels flagged as invalid are replaced by the row mean before filtering, which already limits their influence, so the mask mainly removes the few bits that remain affected.

TABLE V
ABLATION STUDY ON THE TEST SET

Configuration	EER	d'	FRR@FAR 0.1%
Full system	1.94%	4.24	3.00%
No rotation compensation (shift = 0 only)	7.85%	2.65	13.12%
No noise mask (all pixels treated as valid)	2.12%	4.06	2.97%
All radial bands (no inner-band restriction)	2.21%	4.00	3.77%
No iris-radius prior in segmentation	2.56%	4.08	3.78%

F. Robustness

Table VI degrades one probe image per eye (295 probes) and compares it with the clean test gallery at the balanced threshold. The clean probes give FRR 2.17% and FAR 1.49%. Additive noise, mild blur and a reduction in brightness leave the error rates close to the clean case. A $1.4\times$ brightness increase saturates the image and 48 of 295 probes then fail segmentation, which raises the rejection rate. Rotation shows the limit of shift compensation: at 5° the FRR is 3.0%, at 10° it rises to 13.7%, and at 20°, beyond the $\pm 8.4^\circ$ shift range, it reaches 98.4%. Increasing the shift range would handle larger tilts at the cost of a slightly higher impostor-accept rate, since more alignments are tried.



(a) ROC curve

(b) DET curve

Fig. 5. Verification performance on the test set: (a) ROC curve and (b) DET curve, with the EER point marked.

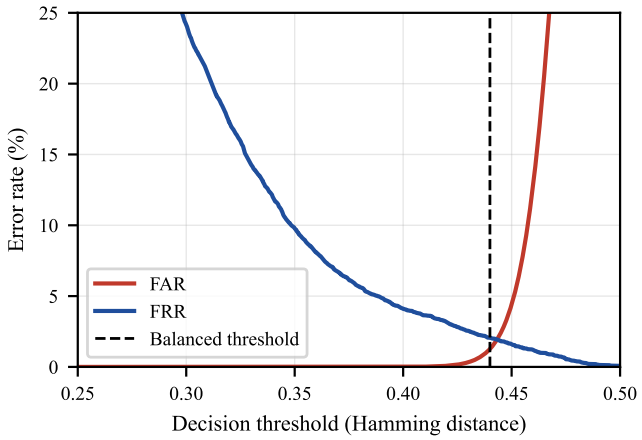


Fig. 6. FAR and FRR as functions of the decision threshold on the test set.

TABLE VI
ROBUSTNESS TO PROBE DEGRADATION (THRESHOLD = 0.44, CLEAN GALLERY)

Probe degradation	Not acquired	FRR	FAR	EER
None (clean probe)	0 of 295	2.2%	1.5%	2.1%
Gaussian noise, $\sigma = 10$	1 of 295	2.7%	1.1%	2.4%
Gaussian noise, $\sigma = 25$	1 of 295	4.3%	0.4%	2.8%
Gaussian blur, $\sigma = 2$ px	3 of 295	2.0%	2.5%	2.1%
Gaussian blur, $\sigma = 4$ px	5 of 295	3.0%	4.0%	3.1%
Brightness $\times$ 0.6	5 of 295	2.1%	1.5%	2.1%
Brightness $\times$ 1.4	48 of 295	8.7%	4.3%	7.2%
Rotation 5°	1 of 295	3.0%	1.4%	2.8%
Rotation 10°	2 of 295	13.7%	1.3%	10.5%
Rotation 20°	4 of 295	98.4%	0.9%	67.8%

G. Security Feature Verification

Table VII summarizes the checks performed on the security mechanisms; all 79 automated tests pass (35 on the store, 14 on input validation, 8 on the web application and 22 on the pipeline). To check that the tests are able to fail, five central defences (account binding of ciphertext, the log's head check, replay rejection, secure deletion and lockout of unknown accounts) were disabled one at a time, and the corresponding test failed in every case.

H. Performance

Table VIII gives the average processing time per image, measured on 100 test images on the development laptop CPU. Enrollment takes 15.1 ms and verification 15.5 ms; segmentation dominates at 13.3 ms, while one code comparison takes 0.42 ms, so searching a gallery of thousands of templates remains practical.

I. Discussion and Limitations

The results show that a classical, fully interpretable implementation of Daugman's pipeline reaches an EER of about 1.94% on a standard NIR benchmark, and that the security layer adds negligible latency. Several limitations apply. First, only one dataset and one sensor were used; the iris-radius prior and the corneal-reflection handling are tuned to a fixed-distance NIR camera, and accuracy on other sensors, on visible-light images or in unconstrained capture is likely to be lower. Second, file names do not identify sessions, so genuine pairs may be taken within a single session, and cross-session results can be expected to be somewhat worse. Third, the test set contains 314 eyes and the 6,632 genuine pairs are correlated (many pairs share images), so confidence intervals on the error rates are wider than the pair counts suggest. Fourth, the test subjects were not entirely blind: although all numeric tuning used only the development subjects, the segmentation stage was debugged by inspecting outlier images from the whole dataset, so the reported test error may be

TABLE VII
VERIFICATION OF SECURITY MECHANISMS (AUTOMATED TESTS)

Mechanism	Test performed	Outcome
Encrypted templates	Searched the database file for the plaintext template bytes	Not found; Fernet token
Tamper detection	Flipped one bit of a stored ciphertext, then verified	Rejected and logged
Account binding	Copied one account's ciphertext into another account's row	Rejected
Wrong key or passphrase	Opened the store with a different key or passphrase	Refused
Key rotation	Rotated the key; verified, checked the log, tried the old key	Works; old key fails
Secure deletion	Deleted a user, searched the file for its ciphertext	Not found
Duplicate identity	Enrolled the same eye under a second name	Refused; other account not named
Username handling	SQL metacharacters, case variants, over-long and non-ASCII names	Rejected; one account
No enumeration	Verified against an unknown, a wrong and an invalid account	Identical denial
Rate limits	5 failures per account, 20 per client, recovery after 301 s	Locked; other clients unaffected
Replay rejection	Verified with the enrolled image, and with an accepted image twice	Rejected; fresh capture accepted
Audit chain	Edited, deleted, reordered and truncated log rows	All detected
Input limits	PNG header claiming 40,000×40,000 px; oversized, tiny and garbage files	Refused before decoding
Web application	Open and password modes, login throttle, score hiding	Admin functions hidden; throttled

TABLE VIII
AVERAGE PROCESSING TIME PER IMAGE (CPU)

Stage	Time (ms)
Segmentation	13.30
Normalization	0.71
Encoding	1.04
Enrollment total	15.06
Matching (one comparison)	0.42
Verification total	15.48

slightly optimistic. Fifth, no ground-truth segmentation was available, and the remaining errors are dominated by poorly segmented, occluded eyes. Sixth, the system does not detect presentation attacks such as printed iris images or contact lenses; it verifies that the presented image matches the template, not that it comes from a live eye. Finally, the encryption key is a file or passphrase on the same host as the database, so compromise of that host exposes both; a deployment should use a key-management service or hardware module, put the application behind TLS, and add network-level rate limits, because the per-client counter is keyed on a session identifier that an attacker can change. The iris codes themselves are not cancelable, so a stolen key plus database would expose templates that cannot be reissued.

VII. SECURITY FEATURES

A. Encrypted, Account-Bound Storage

Iris templates are stored only as Fernet tokens that include the account name. A copy of the database file reveals no template, a modified or swapped template is detected by the authentication tag, and deleted templates are overwritten.

B. Key Management

The key is held outside the data directory with owner-only permissions, can be derived from a passphrase or supplied through the environment, and can be rotated without re-enrolling users.

C. Duplicate-Identity Prevention

Each new template is compared with all enrolled templates under a fixed policy, so a single iris cannot be registered under several identities, and the refusal does not disclose who holds it.

D. Verification Hardening

Unknown and wrong accounts are indistinguishable, failures are rate limited per account and per client, replayed captures are rejected, and the decision threshold is a server-side setting.

E. Tamper-Evident Audit Log

Enrollments, verifications, lockouts, integrity failures and errors are recorded in an HMAC hash chain, and the interface reports whether the chain is intact.

F. Input Validation and Access Control

Uploads are size-limited and checked from the file header, are never written to disk, and match scores are hidden by default. An optional administrator password restricts enrollment, the audit log and the security level (Table IV), and the server listens on the loopback interface only.

VIII. THREAT MODEL AND PRIVACY ANALYSIS

A. Threat Model

We consider an adversary who may present eye images hoping to be accepted as someone else (a zero-effort or targeted impostor), read or copy the database file, modify it, send crafted requests or uploads to the web interface, or repeat attempts to guess. We do not defend against an adversary who controls the running server or the encryption key, nor against presentation attacks that carry the genuine iris texture. Table IX lists each threat with the mitigation implemented and the risk that remains; the unmitigated rows are as important as the mitigated ones, and the lockout itself introduces a denial-of-service risk for the victim account.

TABLE IX
THREAT MODEL: MITIGATIONS AND RESIDUAL RISK

Threat	Mitigation	Residual risk
Zero-effort impostor	Server-side threshold set for a measured FAR; high-security level by default (Table IV)	FAR is 0.13% at the default level, never zero
Hill climbing on match scores	Scores hidden by default; lockout limits attempts	Visible in presentation mode only
Guessing and username spraying	Limits per account (5 per 300 s) and per client (20 per 300 s); identical response for unknown accounts	A new session gets a new client identifier, so real deployments also need network-level limits; the lockout allows denial of service against one account
Database theft	Ciphertext only; key outside the data directory with owner-only permissions; optional passphrase	Key and database on one host: a host compromise yields both
Template tampering or swapping	Authentication tag and account binding; failures logged	Write access can still delete users
Duplicate accounts	1:N check with a fixed policy; quality gate	Detects the same eye only
Replay of a captured image file	Identical captures are rejected	Modified copies and fresh recaptures are not detected
Presentation attack (print, lens, screen)	None	Not mitigated; needs liveness / PAD
Audit-log manipulation	HMAC hash chain with a keyed head, verified in the interface	Rollback to an older consistent snapshot; anyone holding the key can forge
Malicious uploads	5 MB cap; format and size checked from the header; never written to disk	Bugs in the image decoder remain possible
Vulnerable dependencies	Versions pinned; audited with pip-audit; pip and setuptools upgraded	Pillow has no fixed release for Python 3.10; it is kept off untrusted input
Network exposure	Loopback only; optional administrator password	No TLS: use a TLS reverse proxy for remote use
Key compromise plus database copy	None beyond encryption	Templates are not cancelable and cannot be reissued

TABLE X
PRIVACY PROPERTIES: WHAT THE SYSTEM PROVIDES AND WHAT IT DOES NOT

Principle	In this system	Gap
Data minimization	Only the iris code and mask are stored; eye images are processed in memory and never written by the store or the upload path (tested)	Capture devices and logs outside this software are out of scope
Confidentiality	Templates encrypted, authenticated and bound to the account; key kept outside the data directory	Host compromise exposes key and data
Irreversibility	Not guaranteed: images resembling the original can be reconstructed from binary iris templates	Encryption at rest is essential; codes are decrypted in memory for matching
Unlinkability	Not provided: one iris gives comparable codes in every system	Leaked templates from two systems can be linked
Renewability	Not provided: a compromised iris cannot be replaced	Needs cancelable transforms
Purpose limitation	Templates used only for verification and the enrollment duplicate check	Duplicate check touches every stored template in memory
Disclosure to others	Duplicate refusals do not name the other account; visitors cannot list accounts in secure mode	The operator can see the match in the log
Consent and erasure	Deleting a user overwrites the template in the database file (tested) and is logged	No consent screen or self-service deletion in the demo; audit rows keep the username
Log content	Usernames, client identifiers, outcomes and distances; never biometric data (tested)	No retention period defined

B. Privacy Analysis

Biometric data is personal data that cannot be replaced once exposed, and it is regulated accordingly. The GDPR treats biometric data processed to identify a person uniquely as a special category requiring a stricter legal basis [18], and India's Digital Personal Data Protection Act, 2023 requires consent for specified purposes and gives individuals a right to erasure [19]. ISO/IEC 24745 names irreversibility, unlinkability and renewability as the properties of a protected biometric template [17]. We do not claim legal compliance; Table X maps these principles to what the system does and does not do.

The system is strong on data minimization and confidentiality: the eye image is never stored, and the stored template is authenticated ciphertext. It is weak on irreversibility, unlinkability and renewability, which are properties of the template format rather than of the storage layer. Iris codes are lossy, but images resembling the original eye have been reconstructed from binary iris templates [16], so a leaked plaintext template is a genuine privacy loss, and because the same iris produces comparable codes in every system, leaked templates from two systems can be linked to the same person. Encryption at rest reduces the likelihood of such a leak but does not remove the consequence if the key is also compromised. Cancelable templates, in which a revocable per-system transform is applied before storage, are the standard remedy and are listed as future work.

IX. CONCLUSION

This paper presented an iris-recognition-based authentication system that implements Daugman's pipeline—integro-differential segmentation, rubber-sheet normalization, Log-Gabor phase encoding and masked, rotation-tolerant Hamming matching—together with encrypted template storage, duplicate-identity detection, lockout and audit logging. Under a subject-disjoint protocol on CASIA-Iris-Interval the system achieves an EER of 1.94%, d' =4.24 and 96.5% rank-1 accuracy, and the ablation study quantifies the contribution of rotation compensation, the segmentation prior and the radial-band restriction. The remaining errors come mainly

from poorly segmented occluded eyes, which identifies where improvement is most valuable.

X. Future Work

The most direct improvement is more robust localization of occluded pupils, for example with a learned segmentation network, which should lower the error floor visible in the DET curve. Presentation-attack detection, using texture or frequency analysis of the iris and pupil dynamics, is needed before the system can be deployed against active attackers. Cancelable iris codes, in which a revocable user-specific transform is applied before storage, would allow a compromised template to be reissued. Evaluation should be extended to further sensors, cross-session data and visible-light images, and the iris could be combined with a second modality such as face in a multimodal system. Finally, real-time acquisition with NIR hardware and quality feedback would turn the dataset-driven demonstration into a deployable capture station.

References

[1] J. G. Daugman, "High confidence visual recognition of persons by a test of statistical independence," *IEEE Trans. Pattern Anal. Mach. Intell.*, vol. 15, no. 11, pp. 1148–1161, Nov. 1993.

[2] J. Daugman, "How iris recognition works," *IEEE Trans. Circuits Syst. Video Technol.*, vol. 14, no. 1, pp. 21–30, Jan. 2004.

[3] J. Daugman, "Probing the uniqueness and randomness of IrisCodes: Results from 200 billion iris pair comparisons," *Proc. IEEE*, vol. 94, no. 11, pp. 1927–1935, Nov. 2006.

[4] R. P. Wildes, "Iris recognition: An emerging biometric technology," *Proc. IEEE*, vol. 85, no. 9, pp. 1348–1363, Sep. 1997.

[5] L. Masek, "Recognition of human iris patterns for biometric identification," B.Eng. thesis, School of Computer Science and Software Engineering, Univ. Western Australia, 2003.

[6] D. J. Field, "Relations between the statistics of natural images and the response properties of cortical cells," *J. Opt. Soc. Am. A*, vol. 4, no. 12, pp. 2379–2394, 1987.

[7] K. W. Bowyer, K. Hollingsworth, and P. J. Flynn, "Image understanding for iris biometrics: A survey," *Comput. Vis. Image Underst.*, vol. 110, no. 2, pp. 281–307, 2008.

[8] P. Grother, E. Tabassi, G. W. Quinn, and W. Salamon, "IREX I: Performance of iris recognition algorithms on standard images," NIST Interagency Report 7629, 2009.

[9] A. Gangwar and A. Joshi, "DeepIrisNet: Deep iris representation with applications in iris recognition and cross-sensor iris recognition," in *Proc. IEEE Int. Conf. Image Process. (ICIP)*, 2016, pp. 2301–2305.

[10] A. K. Jain, A. Ross, and S. Prabhakar, "An introduction to biometric recognition," *IEEE Trans. Circuits Syst. Video Technol.*, vol. 14, no. 1, pp. 4–20, Jan. 2004.

[11] N. K. Ratha, J. H. Connell, and R. M. Bolle, "Enhancing security and privacy in biometrics-based authentication systems," *IBM Syst. J.*, vol. 40, no. 3, pp. 614–634, 2001.

[12] *Information Technology—Biometric Presentation Attack Detection—Part 3: Testing and Reporting*, ISO/IEC 30107-3, 2023.

[13] Institute of Automation, Chinese Academy of Sciences, "CASIA Iris Image Database (CASIA-Iris-Interval)," http://biometrics.idealtest.org/.

[14] Python Cryptographic Authority, "Fernet (symmetric encryption)," *cryptography* documentation.

[15] G. Bradski, "The OpenCV Library," *Dr. Dobb's Journal of Software Tools*, 2000.

[16] J. Galbally, A. Ross, M. Gomez-Barrero, J. Fierrez, and J. Ortega-Garcia, "Iris image reconstruction from binary templates: An efficient probabilistic approach based on genetic algorithms," *Comput. Vis. Image Underst.*, vol. 117, no. 10, pp. 1512–1525, 2013.

[17] *Information Security, Cybersecurity and Privacy Protection—Biometric Information Protection*, ISO/IEC 24745, 2022.

[18] European Parliament and Council of the EU, "Regulation (EU) 2016/679 (General Data Protection Regulation)," Art. 9, 2016.

[19] Government of India, "The Digital Personal Data Protection Act, 2023," Act No. 22 of 2023.